12/10/26

Case Study II

* Securing the University Examination System

A university uses an Operating System based examination management system to store student records, examination marks, faculty details, and question papers. The system has three main user groups: Student, Faculty, and Administrator. Student should be able to view only their own marks and download permitted learning materials. Faculty members need to view student records and enter or modify marks. Administrators manage user accounts, permissions, and system configuration.

The University has assigned permissions through roles, but an audit review identifies the following events:

At 10:00, the account Student07 has three failed login attempts.

At 10:03, Student07 successfully logs in.

At 10:04, Student07 attempts to open ExamMarks.xlsx, which contains marks for an entire class.

At 10:05, the system records an attempted modification of ExamMarks.xlsx ~~and save the file successfully~~ by Student07.

- At 10:15, Faculty02 modifies [illegible] and saves the file successfully.
- At 10:20, an administrator discovers that a former faculty member's account is still active.
- The audit log is stored on the same server, and users with broad permissions may be able to modify or delete it.

The university wants to protect confidentiality, integrity and availability; prevent unauthorised access; maintain accountability and investigate suspicious activity. You are asked to recommend appropriate operating system access-control, security-administration and audit measures.

Questions:-

Q1. Identify the main security problems in the case study. List atleast four risks or weaknesses indicated by the scenario.

Q2. Explain the difference between authentication and authorization using Student07 as an example. Distinguish identity verification from permission checking.

Q3. Recommend an access control policy for students, Faculty and Administration. Justify your choice. Consider how permissions should be assigned and managed.

Q4. Prepare a suitable Access Control List (ACL) for exam Marks.xlsx.
Specify appropriate Read, Write and Delete permissions for each user group.

Q5. Explain how the principle of least Privilege should be applied in this system.
State what each group needs to do and which unnecessary permission should be removed.

Q6. Interpret the audit events from 10:00 to 10:05.
What should the security team do next?
Explain why the sequence is suspicious without assuming that it proves an attack.

Q7. Identify at least five events that should be recorded in the audit logs.
Include logon, file, account, permission, and/or administrative events.

Q8. Explain why the audit logs must be protected and recommend two ways to protect them.

Q9. Consider unauthorized modification, deletion, and investigation.

Q9. What action should be taken regarding the former faculty member's active account? Explain

Relate your answer to account management and access removal.

Q10. Suggest a practical incident-response and corrective action plan for the university.

Include investigation, access review, policy changes and follow-up monitoring.

1) Ans • Student07 makes 3 failed login attempts that might suggest a problem with the password or unauthorized login.

• Student07 logs in successfully and then tries to open the ExamMarks.xlsx file with marks of all students.

• Student07 tries to alter the marks file, although the students should not be authorized to make any changes.

• A former faculty member's account is active and might provide unauthorized access to the university resources.

2) Ans Authentication refers to proving - to the computer - who you are. In the given case, Student07 made three failed login attempts at 10:00, followed by a successful login at 10:03.

Authorization refers to determining what you are allowed to do on the system. Student07 may be authorized to view the permitted learning materials and marks, but he/she should not be able to make any changes to the ExamMarks.xlsx file.

Thus, authentication verifies the user's identity, whereas authorization ensures that they are only able to perform the permitted actions.

3) Ans The university's information security system should adopt a Role-Based Access Control (RBAC) model wherein users roles determine what they can or cannot do on the system.

Students: View their own marks, and download permitted learning materials.

Faculty: View the student's records and update or alter the marks for the corresponding subjects.

Administration: Alter the system access rules and user permissions for different roles.

I think this access-control policy is appropriate because it is easier to manage, and it does not allow unauthorized users to access the system.

Additionally, I would recommend auditing user's access rights periodically to ensure that they only have the permissions to perform the necessary tasks.

4) Ans

User group	Read	Write	Delete
Students	Own marks only	–	no
Faculty	Yes – for assigned students		
Subjects	Yes – for assigned marks only		
Administrations	when required only and authorized		

the above ACL is appropriate for the spreadsheet containing student's confidential marks. For instance, students cannot write or delete any content in the spreadsheet; but they can view. Faculty members can view and write student marks for the corresponding subjects, but they should be denied any delete operation.

5) Ans The Principle of Least Privilege states that users should only be given the minimum permission needed to perform their daily tasks.

Students should only be provided with a view of their own marks and should not be allowed to make any changes to the ExamMarks.xlsx file.

Faculty members should be only able to view and update the marks for the corresponding subjects, but they should be denied by delete operation.

Administrators should be given access to the user accounts permissions, and system configuration but they should be denied any unauthorized file editing or deletion features.

Thus, the principle of Least Privilege ensures that users will not have unnecessary access to the university's information system.

6) Any I think the sequence of activ... suspi... because Student07 made three failed login requests at 10:00, successfully logged in at 10:03, tried to open the ExamMarks.xlsx file at 10:04, and finally attempted to alter the spreadsheet at 10:05.

Such behaviour might suggest that Student07 is not authorized to view or change the student marks. I think the security team should take the following steps:-

- Review the login attempts and verify if the Student successfully logged in by utilizing the provided credentials.
- Check if the Student07 was authorized to view the marks.
- Review whether Student07 has successfully altered the marks.
- Ensure that the audit logs are preserved for future reference.

The faculty members successful marks update at 10:15 should also be reviewed against the permissions that they were provided. I also think that the ex-faculty members active account should be

investigated and disabled.

7) Any The university should ensure that the following events are recorded.

- Successful and failed login attempts.
- Attempts to view or access any files.
- Alteration made to students marks records.
- User account creation, modification or deletion.
- Changes to the user role or access permission.
- Updating or reviewing the system setting or configuration.

The above activities should be recorded because it will help the university respond to suspicious activities or incidents effectively

8) Any Audit logs must be protected because they can be used as evidence to prove any security incidents occurring in the university's information system. Without the logs, it will be impossible to trace who made specific changes to the system, which might hinder incident response and legal investigations.

I recommend the following two security measures:-

- Only the authorized or authenticated users should be able to view or modify the audit logs.
- The logs should be protected using secure and reliable auditing tools.

Thus, the logs should always be protected with strong encryption tools to prevent unauthorized users from deleting or modifying the contents.

9) Ans The university should ensure that the former faculty member's account is disabled and is denied access to the university's information system.

The faculty member should be prompted to close all active sessions and ensure that their activities will not affect the system's confidentiality, integrity and availability.

I think this action is important because it will enhance the security of the information system by eliminating former users access to the system.

(b) Act. Investigate :- The university should review the audit events in details and confirm if Student07 actually made unauthorized access to the system and altered the student marks.

Review access :- The university should ensure that the former faculty members account is disabled and no longer has access to the system. Additionally, the system's administrator should review the current user roles and ensure that everyone has the least privileges to access the university resources.

Improve Security :- The university should consider applying stricter security measures, including the Role-Based Access control and the Principle of Least Privilege.

Monitor regularly :- The university should ensure that the audit logs are protected and that no unauthorized activities are occuring in the system.

I think the above plan will help the university respond to the given security incident and ensure that unauthorized access or marks alteration

does not occur in the future. It will also increase the security of the information system storing student's confidential data.